



FINANCEFIRST CREDIT UNION

GRC 205 - INCIDENT MANAGEMENT AND BUSINESS CONTINUITY

TOPIC: INCIDENT RESPONSE PLANNING

COMPILED BY: GROUP 4

DATE: WEEK 20 (14 DECEMBER 2025)

INSTITUTION: INTERNATIONAL
CYBERSECURITY AND DIGITAL FORENSICS
ACADEMY (ICDFA)



Table of Contents

GRC 205 - Incident Management and Business Continuity	Error! Bookmark not defined.
Week 20: Practical Simulation Lab Assignment.....	Error! Bookmark not defined.
(Ransomware Incident Response Simulation)	Error! Bookmark not defined.
Brief Organization Background	5
Phase 1: Detection and Initial Response (Hour 0-4)	6
PHASE 1: DETECTION AND INITIAL RESPONSE (HOUR 0-4)	7
➤ Reputation and Trust Implications	15
11. Media Response Strategy	21
12. Next 24-Hour Action Plan	22
Immediate priorities	22
Timeframe	22
Immediate Priorities	22
0-6 Hours.....	22
Accelerate forensics analysis	22
- To confirm initial access point, time of compromise.	22
6-12 Hours.....	22
Secure Network and Credential Ejection	22
12-18 Hours.....	23
- Isolate and configure a clean, new Virtual Local Area Network (VLAN) designated only for restoration activities.	23
- Ensure branches continue using the isolated core banking system for transactions.	23
18-24 Hours.....	23
- Prepare a detailed update for the executive team and the board covering current scope of impact, forensic findings available, risk assessment, status of containment, business impact and projected downtime.	23
- Determine preliminary recovery strategy.	23
Resource Requirements	23
Expected Outcomes.....	24
Key Decisions Required from Executives	24
PHASE 2: CONTAINMENT AND INVESTIGATION (HOUR 4-24).....	24
13. Breach Notification Determination	24



1. What Data Elements Were Compromised?	24
2. Does This Meet the Legal Definition of a Breach?	25
3. Notification Obligations & Timelines	25
State Breach Notification Laws	26
Credit Bureaus	26
Law Enforcement	26
Members	26
Do you agree with the forensic team's recommendation for a full network rebuild?	26
➤ Can We Safely Eradicate Without a Full Rebuild?	27
➤ Estimated Timeline & Cost: Rebuild vs Targeted Remediation	27
➤ Business Impact of Each Approach	28
• Full Rebuild	28
• Targeted Remediation	28
➤ Risk of Reinfection	29
Full Rebuild	29
• Targeted Remediation	29
PHASE 3: RECOVERY AND RESTORATION (HOUR 24-48)	36
23. Implementation Plan	42
1. Phase-by-Phase Restoration Sequence	42
➤ Phase 1: Immediate Stabilization (Hour 0–12)	42
➤ Phase 2: Critical System Decryption and Temporary Restoration (Hour 12–48)	42
➤ Phase 3: Parallel Full Network Rebuild (Day 2–Day 21)	42
➤ Phase 4: Validation and Testing (Day 15–Day 21)	43
➤ Phase 5: Full Operational Recovery (After Day 21)	43
2. Resource Requirements	43
➤ Personnel	43
➤ Equipment and Technology	43
➤ Budget (Estimated)	43
3. Validation and Testing Procedures	44
➤ Rollback Procedures (If Issues Arise)	44
➤ Communication Plan for Stakeholders	45
34. Detailed Timeline of Events from Initial Compromise Through Resolution	61
The initial compromise, attacker dwell time discovery, containment, eradication and full recovery are all covered in this thorough account of the incident lifecycle.	
According to forensic evidence, the attacker had undetected access for about 21 days.	



After thorough credential harvesting, reconnaissance and exfiltration of regulated data, the attack culminated in the deployment of REvil ransomware. The recovery period spans over three weeks.	62
Each step in the NIST Incident Response life cycle is described in the timeline that follows.....	62
➤ Attack Vector and Methodology	63
The incident was linked to a phishing email that contained a malicious macro-enabled document, according to forensic analysis. After the document was executed, TrickBot was installed, allowing the attacker to download additional tools, create persistence, and gradually increase their privileges.	63
In order to evade detection, the attacker used legitimate administrative tools (Living off the Land) and operated in a manual multi-stage manner typical of human-operated ransomware. As outlined below, the attack progression is consistent with the MITRE ATTACK framework.	63
MITRE-Mapped Attack Methodology	63
➤ Systems Affected	63
➤ Data Impacted	64
Forensic Findings and Evidence	64
Logs impacted systems and data flows were thoroughly examined by a contracted forensic company. Their conclusions provided crucial information about the attackers' strategies, persistence tactics, the attack timeline, and the degree of data exfiltration. important findings are highlighted below:	64
• First Access: The entry point was confirmed to be a phishing email that sent a macro-enabled document.	64
• Dwell Time: Before beginning encryption, the attacker remained active within the environment for twenty-one days.....	64
• Data Exfiltration: Outgoing traffic of about 340GB to the attacker command and control (C2) servers was discovered in firewall and SIEM logs.	64
• Persistence Mechanisms: Full rebuilding is needed rather than part cleanup for service accounts and unauthorized scheduled tasks that are already confirmed to be involved.....	64
• Ransomware Family: Found to be a custom-configured variant of REvil/Sodinokibi. 64	
➤ Evidence Collected & Chain of Custody	64
In order to support regulatory and possible legal proceedings, the response team maintained a well-documented, clear, and verifiable chain of custody for all materials gathered.....	64
Items of Evidence.....	64
• Five server disk images.....	64



- Dumps of memory.....64
- Firewall and SIEM logs.....64
- Ransom note artifacts.64
- Attacker IP addresses are included in the list of Indicators of Compromise (IOCs). 64

The Practices of The Chain of Custody.64

- All evidence is hashed and kept in a secure location.....65
- Access logs are maintained during the handling procedure.....65
- Information given to the FBI complies with federal regulations.65

Tactics, Techniques, and Procedures of Attackers (TTPs).65

By encrypting local systems and threatening to release stolen data, the attacker used a sophisticated, financially motivated ransomware approach that included social engineering, credential theft, covert internal movement, and double-extortion tactics.65



Introduction

This document details the Security Incident at FinanceFirst Credit Union, a regional financial institution serving 85,000 members across the Southeastern United States, the incident response activities, the challenges faced, mitigation efforts, implemented controls, and the lessons learned.

Brief Organization Background

Organizational Attribute	Details
Industry	Financial Services (Credit Union)
Member Base	85,000 active members
Employee Count	320 employees across 12 branch locations and 1 headquarters
Assets Under Management	\$1.2 billion USD
Services Offered	Checking/savings accounts, mortgages, auto loans, business banking, online/mobile banking
Regulatory Requirements	NCUA, FFIEC, GLBA, state banking regulations
IT Infrastructure	Hybrid environment with on-premises core banking system, cloud-based CRM, and member portal
Security Posture	Moderate - basic security controls, annual penetration testing, security awareness training
Incident Response Maturity	Developing - IR plan exists but has not been tested in real incident

**Phase 1: Detection and Initial Response (Hour 0-4)****(Monday, 6:45 AM)**

On Monday, 6:45 AM an we received an urgent call from the **Night Shift System Administrator** who reported the following:

*"We're seeing something very strange. Starting about 20 minutes ago, our monitoring system started showing massive file activity on several file servers. Users are calling the help desk saying they **can't access shared drives**. When I checked one of the servers, I found a text file on the desktop that wasn't there before. It's called 'READ_ME_NOW.txt' and it says all our files have been encrypted and we need to pay Bitcoin to get them back. This looks like ransomware."*

The ransome note reads as follows:

YOUR FILES HAVE BEEN ENCRYPTED

All your important files, including databases, documents, and backups, have been encrypted with military-grade encryption. You cannot recover them without our decryption key.

WHAT HAPPENED?

Your network security is weak. We have been inside your systems for 3 weeks, stealing your data and preparing for encryption. We now have:

- Complete member database (names, SSNs, account numbers, balances)
- Employee records and payroll data
- Internal communications and emails
- Backup systems (also encrypted)



WHAT DO WE WANT?

Payment of 75 Bitcoin (\$2.8 million USD at current rates) within 72 hours.

If you pay within 24 hours: 50 Bitcoin (\$1.9 million USD) - 32% discount

If you pay within 72 hours: 75 Bitcoin (\$2.8 million USD)

If you do not pay within 72 hours: 150 Bitcoin (\$5.6 million USD) + we publish your member data on the dark web

DO NOT:

- Contact law enforcement (we are monitoring your communications)
- Attempt to decrypt files yourself (you will corrupt them permanently)
- Restore from backups (we encrypted those too)

TO PAY:

Contact us at: [TOR hidden service address]

Bitcoin wallet: [Bitcoin address]

You have 72 hours. The clock is ticking.

PHASE 1: DETECTION AND INITIAL RESPONSE (HOUR 0-4)

1. Immediate Actions

- Validate and classify the incident.
- Isolate the affected system/server
- Start preserving logs and evidence for investigation.

2. Initial Assessment

- This is a confirmed security incident because of the unusual activity noticed on the system, a message from night shift staff, as well as the README.txt.



- Our preliminary severity assessment of the Incident is Critical for the following reasons:
 - Business disruption
 - Reputational damage
 - They have our files at Ransom.
- Suspected Incident type and attack vector
 - Incident Type: Ransomware
 - Attack Vector: Likely from phishing (user clicked a malicious link or attachment)

3. Stakeholder Notification

1. CISO Security Incident Notification

To: CISO

Subject: URGENT - Incident Response Activation: 20251208-Ransome-001

We have detected a ransomware attack affecting multiple servers and critical data.

Ransom note demands payment and claims data exfiltration. I am initiating the incident response plan and will provide updates as we assess the scope.

The Computer Security Incident Response Team (CSIRT) has been activated in response to a confirmed security incident.

Incident Details:

Incident Number: 20251208-Ransome-001

Detection Time: Monday, December 8, 2025 at 6:45 AM

Severity Level: Critical

Incident Type: Ransomware

Affected Systems:

- Complete member database (names, SSNs, account numbers, balances)
- Employee records and payroll data



- Internal communications and emails
- Backup systems (also encrypted)

Immediate Actions Required: All CSIRT members have been directed to:

- Check in via the secure communication channel.
- Review their assigned role and responsibilities.
- Ensure they have access to all necessary tools and systems
- Stand by for the initial incident briefing at 7:00AM today.

Secure Communication Channel: Google Meet/Microsoft Team

CSIRT Members Security Incident Notification

To: CSIRT Members

Subject: URGENT - Incident Response Activation: 20251208 -Ransome-001

Body:

We have detected a ransomware attack affecting multiple servers and critical data.

Ransom note demands payment and claims data exfiltration. We are therefore initiating the incident response plan to address this situation.

Incident Details:

Incident Number: 20251208-Ransome-001

Detection Time: Monday, December 8, 2025, at 6:45 AM

Severity Level: Critical

Incident Type: Ransomware

Affected Systems:

- Complete member database (names, SSNs, account numbers, balances)
- Employee records and payroll data
- Internal communications and emails



- Backup systems (also encrypted)

Immediate Actions Required: All CSIRT members are required to immediately:

- Check in via the secure communication channel.
- Review their assigned role and responsibilities.
- Ensure access to all necessary tools and systems
- Stand by for the initial incident briefing at 7:00AM today.

Secure Communication Channel: Google Meet/Microsoft Team.

Thank You.

Yours Sincerely,

IR Manager.

4. Evidence Preservation and Chain of Custody Maintenance Activities

- Isolate the affected systems without powering off.
- Document the incident and the chains of custody.
- Record date, time and personnel who discovered the incident.
- Document all actions taken, security logs and screenshots.
- Ensure that only authorized personnel access the affected systems.

Scope Assessment (Monday, 7:30 AM)

5. Critical Containment Decisions

- Disconnect the affected systems from the server to avoid lateral movement.
- The entire network will not be shut down to prevent the following:
 - ✓ Disruption of core business activities which will result in stakeholders' panic.
 - ✓ Complete data loss.
 - ✓ Frustrated customers and reputational damage



- ✓ Loss of business partners.
- The branch locations will not be closed rather operations will be limited with an enabled notification on the customer's app eg: *please note that the bank will be experiencing downtime due to a system upgrade between 24 hours.*
- This decision is necessary and timely to avoid further damaging impact like:
 - ✓ Customer panicking due to significant business disruptions.
 - ✓ Reputational damage, which will cause loss of business.
 - ✓ Potential evidence destruction.
- This decision shows that the organization has effective and functioning leadership structure that ensures good decisions are taken during crisis for the interest of the business.

6. Containment Strategy

a. Specific Technical actions to isolate the threat and Timelines

Actions	Timeline
• Isolate and disable all encrypted server from the network interface. • Segment Domain controller from the general user network. • Block all remote Powershell, administrative access and Remote Desktop Protocol (RDP) across all segment. • Activate out of band communications channels for safe and effective communication • Block attackers IP address	0-30 minutes



• Identify and isolate all infected workstations. • Reset password for all privilege and admin accounts. • Configure firewall to deny all traffic between the headquarter except for core banking systems. • Copy all disk and memory images of compromised server for evidence preservation.	30-60 minutes
• Block ransomware file extension REvil/Sodinokibi to prevent further privilege escalation. • Disconnect all backups from the server and validate if there are safe unencrypted backups.	1-2 hours

Expected business impact**Positive**

- Prevent further privileged escalation to other core banking functions.
- Ensures that essential services are running in other branches.
- Reduces Regulatory fines when they see genuine effort at containment.
- Help preserve evidence for forensic

Negative

There will be a significant downtime in operations.



analysis.

- Reduces the business impact of the security incident.

Mitigation measures to maintain critical operations

- Patch and update software.
- Disconnect outdated servers.
- Implement access control e.g, least privilege or MFA to limit access to privileged accounts.
- Implement network segmentation to prevent all banking network from being affected

7. Engagement of External Resources

We therefore recommend engaging external resources. Reasons, benefits and cost of engaging external resources are highlighted in the table below.

Cost-benefit analysis for Engaging External Resources

External Support	Cost	Benefit Analysis
Forensic investigation firm	\$50,000-\$200,000	Will help in deep analysis to find out the root cause of the incident. Prevent future incident.
Ransomware negotiation specialist	\$100,000-150,000	Will buy time for the organization while containment, eradication and recovery efforts are ongoing.
Legal counsel specializing in cyber incidents	\$60,000-\$200,000	Engaging them will help the organization weigh and



		understand their legal options, what they're faced with and what they can do to minimize the legal impact.
Cyber insurance carrier	\$1,000,000-	They will help in sharing the financial burden incurred in this security incident. This will cushion the financial effect on the organization.

8. Communication Strategy

We strongly advise informing our members about the incident promptly for the following reasons.

- To meet legal and regulatory requirements, as mandated by GLBA and state laws. Quick notifications show transparency and help maintain member trust, especially since the media and regulators already know about the situation.
- Waiting to disclose or withholding information could cause more reputational damage if members learn from other sources. Early communication allows us to guide members on protective actions, reducing the risk of harm and liability.
- Proactive disclosure also allows us to shape the narrative and demonstrate responsible leadership during a crisis. Ultimately, timely notification best safeguards our members' interests and the long-term reputation and integrity of Finance First.

➤ Legal and Regulatory Obligations

- GLBA and State Laws: Both require notifying members as soon as possible if unauthorized access to sensitive customer information is confirmed.
- Current Forensic Evidence: Network logs show 340GB of exfiltrated data, including PII, SSNs, account numbers, and financial records for 85,000 members.



➤ **Mandatory Notification:**

- We are legally obligated to notify affected individuals, state regulators, and federal agencies such as NCUA and possibly credit bureaus.
- Notification timelines range from “without unreasonable delay” to 30–45 days, but public data disclosure speeds up this timeline.
- With media and dark web leaks confirmed, a delayed notification is not appropriate. defensible
- Supporting Templates: Our Data Breach Incident Response Template and Communication Templates Guide offer approved language and checklists for this process.

➤ **Reputation and Trust Implications**

- Transparency creates trust by encouraging proactive and honest communication, which demonstrates accountability and respect for our members. This approach helps sustain credibility and promotes long-term loyalty.
- Media and Social Media Pressure: Since the breach is already public and member data has been leaked, any effort to delay or minimize the issue would be rapidly uncovered, causing further damage to the reputation.
- Regulatory Scrutiny: Agencies look for quick, transparent communication and tend to be less punishing when we are proactive.

➤ **Timing Considerations**

- **Immediate Notification Required:**
 - Immediately notify staff and the call center to ensure they are ready for member inquiries.



- **Members:** Respond as soon as possible, ideally within 24–48 hours, now that public disclosure has taken place.
- **Regulators:** NCUA is to be notified within 72 hours, other stakeholders like the state regulators are to be notified too, and file SAR with FinCEN if required.
- **Delay Risks:** Any delay raises legal risks, damages trust, and may lead to regulatory penalties.

➤ **Other information to disclose (if any)**

- What to Say:
 - What occurred cyberattack, data exfiltration, and evidence of a public leak
 - What type of information was involved, such as name, SSN, and account numbers
 - Our current activities include containment, law enforcement coordination, and remediation.
 - Members should monitor their accounts, utilize credit monitoring services, and contact us when needed.
 - Available resources include the call center, website, and credit protection offer.
 - Commitment to continuous updates and transparency
- How to Say It:
 - Use clear, honest, and empathetic language (refer to templates in Communication_Templates_Guide.docx and Data_Breach_Incident_Response_Template.docx)
 - Avoid using technical jargon and speculation.
 - Only confirm what has been validated by forensics and legal review.
 - Obtain pre-approval for all communications from General Counsel and the Communications Officer.

9. Ransom Payment Recommendation

Ransom Payment Recommendation:

Our expert advice for Finance First Credit Union is to refuse to pay the ransom due to



technical, legal, ethical and commercial factors highlighted below.

Technical considerations

- Likelihood of successful decryption: The technical outcome is highly uncertain and risky even if paying the ransom is legal.

Probability of successful decryption: Attackers' decryption tools are often unreliable, faulty, or insufficient. Only some of the corrupted files or decryption keys that fail after a few uses could be sent to TMS.

Reinfection risk: The recovery process often involves using the attacker's tools, which may include logic bombs, backdoors, or persistent malware designed to re-infect the system after recovery, leading to a second, more damaging attack.

Incomplete removal: Paying does not guarantee that a time-delayed payload was not left behind or that the attacker has been completely removed from the network.

Legal and regulatory implications (FBI guidance, regulatory expectations)

- Regulatory and legal ramification: There are serious risks associated with paying the ransom which could pose serious legal and regulatory hot water issues for the organization than the actual data loss.
- FBI Recommendations: The U.S. The FBI and CISA strongly advise against paying ransoms. The criminal ecosystem is thought to be fueled by payment.
- Regulatory Expectation (HIPAA/PCI): Rather than payment, regulatory bodies require thorough preparation. Ransom payments may indicate insufficient security measures particularly in the wake of a data breach. Instead of giving up, the emphasis should be on exhibiting the utmost diligence in recovery and remediation.
- Sanctions Risk: The ransom payment may unintentionally violate U. S. laws though this is unlikely in every situation. In the regulations of the Office of Foreign Assets Control (OFAC) if the money is transferred to a company or individual on the sanctions list there are harsh civil and criminal penalties for this.

Ethical considerations (funding criminal enterprises, encouraging future attacks):

- Organizational ethics and responsible cybersecurity practices are directly at odds with the payment decision.
- Funding Criminal Enterprises: Payment provides the criminal enterprise with direct funding and validation, boosting their resources and promoting more advanced attacks against TMS and the healthcare industry in the future.
- Encouraging Future Attacks: Because they are perceived as soft targets ready to finance illicit activities, businesses known for paying ransoms become more attractive targets for future attacks.

**Business considerations (cost-benefit analysis and operational impact):**

- Financial Cost: The sum of the ransom (typically millions) plus the cost of negotiations. Personnel time forensic consulting fees and system reconstruction expenses.
- Operational Impact: If decryption is incomplete or fails there could be a protracted outage. controlled downtime with an emphasis on clean recovery through tried-and-true techniques.
- Data Integrity: There is a significant chance of data loss corruption or persistent encryption. When restoring from clean verified backups there is a high level of confidence in data integrity.
- Reputation: The public and customers unfavorable opinion of a business that finances criminal activity. favorable opinion of a robust business that bounces back professionally.

Alternative options (recovery from backups, system rebuilding):

- Recovery from Backups (Carry out IRP Phase 3): Recovery Procedures entails separating the impacted environment and re-establishing systems from clean verified air-gapped backups (essential for PHI and proprietary algorithms). Highest level of system security and data integrity assurance. Avoids giving money to criminals.
- Rebuilding the system from scratch: Using hardened images and clean configurations is recommended for highly critical systems where backup integrity is in doubt. Reduces the possibility that the attacker may have left behind malware.
- Forensic Investigation: Before attempting recovery, have the Cyber Forensic Firm perform a Root Cause Analysis (RCA) to ascertain the scope of the initial intrusion vital for regulatory reporting legal compliance and the long-term elimination of the attack vector.

10. Ransom Payment Recommendation:

The expert advice for TechMed Solutions is to refuse to pay the ransom due to technical, legal ethical, and commercial factors. Phase 3 of the established Incident Response Plan (IRP): Containment, Eradication, and Recovery must be carried out with verified backups.

- **Technical considerations (likelihood of successful decryption, reinfection risk):** The technical outcome is extremely uncertain and dangerous even if paying the ransom were lawful.



- **Probability of Successful Decryption:** Attackers' decryption tools are frequently faulty, untrustworthy or insufficient. Only a portion of the corrupted data files or decryption keys that break after a few uses could be sent to TMS.
 - **Reinfection Risk:** The recovery technique frequently entails using the attacker's tools, which might include logic bombs, backdoors or persistent malware, intended to re-infect the system following recovery, resulting in a second, more destructive attack.
 - **Incomplete Removal:** Paying does not ensure that a time-delayed payload has not been left behind or that the attacker has been completely removed from the network.
- **Legal and regulatory implications (FBI guidance, regulatory expectations):**
- **Regulatory and legal ramifications.** There are serious risks associated with paying the ransom, which could put you in more legal and regulatory hot water than the actual data loss.
 - **FBI Recommendations:** The U.S. The FBI and CISA strongly advise against paying ransoms. The criminal ecosystem is thought to be fueled by payment.
 - **Regulatory Expectation (HIPAA/PCI):** Rather than payment, regulatory bodies require thorough preparation. Ransom payments may indicate insufficient security measures, particularly in the wake of a data breach. Instead of giving up, the emphasis should be on exhibiting the utmost diligence in recovery and remediation.
 - **Sanctions Risk:** The ransom payment may unintentionally violate U. S. laws, though this is unlikely in every situation. The S. regulations of the Office of Foreign Assets Control (OFAC) if the money is transferred to a company or individual on the sanctions list. There are harsh civil and criminal penalties for this.
- **Ethical considerations (funding criminal enterprises, encouraging future attacks):**
- **Organizational ethics and responsible cybersecurity practices** are directly at odds with the payment decision.
 - **Funding Criminal Enterprises:** Payment provides the criminal enterprise with direct funding and validation, boosting their resources and promoting more advanced attacks against TMS and the healthcare industry in the future.
 - **Encouraging Future Attacks:** Because they are perceived as soft targets ready to finance illicit activities, businesses that are known to pay ransoms become more attractive targets for future attacks.
- **Business considerations (cost-benefit analysis, operational impact):**
- **Financial Cost:** The sum of the ransom (typically millions) plus the cost of negotiations. personnel time forensic consulting fees and system reconstruction expenses.
 - **Operational Impact:** If decryption is incomplete or fails there could be a protracted outage. controlled downtime with an emphasis on clean recovery through tried-and-true techniques.



- **Data Integrity:** There is a significant chance of data loss corruption or persistent encryption. When restoring from clean verified backups there is a high level of confidence in data integrity.
- **Reputation:** The public and customers unfavorable opinion of a business that finances criminal activity. favorable opinion of a robust business that bounces back professionally.

➤ **Alternative options (recovery from backups, system rebuilding):**

- **Recovery from Backups (Carry out IRP Phase 3):** Recovery Procedures entails separating the impacted environment and reestablishing systems from clean verified air-gapped backups (essential for PHI and proprietary algorithms). highest level of system security and data integrity assurance. avoids giving money to criminals.
- **Rebuilding the system from scratch:** Using hardened images and clean configurations is recommended for highly critical systems where backup integrity is in doubt. Reduces the possibility that the attacker may have left behind malware.
- **Forensic Investigation:** Before attempting recovery have the Cyber Forensic Firm perform a Root Cause Analysis (RCA) to ascertain the scope of the initial intrusion. vital for regulatory reporting legal compliance and the long-term elimination of the attack vector.

1. Regulatory Notification Analysis

○ **What evidence exists of data exfiltration vs. encryption only?**

- **Data Exfiltration:** These days double extortion in which data is taken before encryption is the most common type of ransomware attack. Attorneys will assume that there was a violation. The attackers did give the impression that they can expose the data in their possession to the public.

- If you do not pay within 72 hours: 150 Bitcoin (\$5.6 million USD) + we publish your member data on the dark web

- **Encryption Only:** Under HIPAA/State Law, notification might not be necessary if PHI was not accessed or if encrypted data is still intact (i.e. the encryption key was not taken).

○ **What are the specific notification triggers under GLBA and state laws?**

GLBA:



- **Scope:** Under the FTCs broad definition TMS may be considered a financial institution and be subject to the FTC Safeguards Rule if it provides services like financing credit advice or insurance.
- **Trigger:** At least 500 customers unencrypted customer data obtained without authorization.

Laws Concerning State Breach Notification (e.g. CA NY and TX).

- **Trigger:** When a state residents PII (usually their name plus SSN driver's license account number or medical information) is obtained without authorization.
- **What is the timeline for notification if required?**
 - **FTC (If GLBA applies):** If more than 500 consumers are impacted no later than *30 days* following discovery. after confirmation of the P1 incident within seven days.
 - **HHS OCR (HIPAA):** Within 60 days following discovery. (Media/HHS must be informed within 60 days if more than 500 people are impacted). The internal deadline is 45 days.
 - **State AGs (State Law):** As quickly as possible and without unjustified delay (some states require shorter specific windows e. g. 30 days). within 45 days (or as soon as the state specifies).
- **What are the consequences of premature vs. delayed notification?**
 - **Legal/Regulatory:** Inaccurate information may result in additional liability and necessitate expensive follow-up corrective notifications. If a delay in notifying the proper parties, it could complicate ongoing criminal investigations and result in massive fines (e. g. HIPAA and GDPR). Customer lawsuits (aggrieved class action). Heightened scrutiny from FTC/HHS regulators who consider delays to be careless.
 - **Business/Reputation:** Unverified scope causes customers to panic. Confusion among the public and needless harm to one's reputation could result in a loss of business and a decline in customer confidence and if there is a delay informing the public, the price of stocks of First Finance Credit Union will drastically decline.

11. Media Response Strategy

For Immediate Release (Monday 11:00am)

Finance First Responds to System Disruptions



We are currently experiencing network disruptions affecting some of our internal systems due to a security incident that was discovered on Monday, December 8, 2025. We understand the concern this may cause to our customers and partners, we want to reassure you that our core banking systems, online banking, and mobile services remain fully operational and functional.

We apologize for the inconvenience this has caused and we are working closely with our technical teams and external experts to assess the situation and restore full functionality to all affected systems securely.

We are conducting a thorough assessment to determine the full scope of the incident. The security and privacy of our customer's information is our highest priority and we are taking every step necessary to safeguard our systems.

We are committed to transparency and will provide updates as our investigation progresses with verified information.

Customers with questions can visit:

helpdesk@financefirst.com or call (345)289-23457).

12. Next 24-Hour Action Plan

Immediate priorities

Timeframe

Immediate Priorities

0-6 Hours

Accelerate forensics analysis

- To confirm initial access point, time of compromise.
- Identify the exact vulnerability/method the attacker used.
- Identify and remove persistence.
- Confirm the volume and type of data stolen and encrypted.
- Secure ransom notes, timestamps, and artifacts in an evidence repository following chain-of-custody procedure

6-12 Hours

Secure Network and Credential Ejection



	- Apply temporary firewall rules to restrict outbound traffic from internal networks to only essential services. - Strengthen segmentation to protect core banking and cloud systems. - Force reset all privileged accounts and implement MFA on all remaining external access points.
12-18 Hours	- Isolate and configure a clean, new Virtual Local Area Network (VLAN) designated only for restoration activities. - Ensure branches continue using the isolated core banking system for transactions. - Redirect internal staff to approved communication channels such as secured messaging apps or emergency email fallback systems. - Coordinate with legal counsel on regulatory timelines and prepare draft notification templates.
18-24 Hours	- Prepare a detailed update for the executive team and the board covering current scope of impact, forensic findings available, risk assessment, status of containment, business impact and projected downtime. - Determine preliminary recovery strategy.

Resource Requirements

- Incidence Response Manager
- Internal IT Security and Operations Team
- External Forensic Firm
- Legal Counsel
- CISO and executive leadership for decision making, and resource allocation
- Secure communication channels for executives and CSIRT
- Technical tools and access (SIEM, EDR)
- Out-of-band communication system



- Cyber Insurance Carrier.

Expected Outcomes

- Confirmation of root cause.
- Preservation of critical forensic evidence.
- Initial understanding of the attack vector and potential data exposure.
- Stabilization of the spread and core business processes.
- Draft communication materials prepared for regulators and members.
- Clear communication lines with leadership and branches.
- Executive consensus on negotiation stance and resource allocations.

Key Decisions Required from Executives

- Data breach notification authorization.
- Recovery strategy confirmation.
- Whether to authorize negotiation engagement.
- Full scale system rebuilding and mass restoration approval.
- Direction on public communications beyond the holding statement.
- Funding approvals for containment and short-term recovery expenses.

PHASE 2: CONTAINMENT AND INVESTIGATION (HOUR 4-24)

Inject 2.1 - Forensic Findings (Monday, 2:00 PM)

13. Breach Notification Determination

1. What Data Elements Were Compromised?

Forensics confirm that approximately 340GB of sensitive member data was exfiltrated before systems were encrypted. Compromised elements include:

- Full names
- Addresses
- Dates of birth



- Social Security Numbers (SSNs)
- Account numbers
- Transaction history
- Loan information
- Credit card data
- Employee credentials, some privileged accounts
- These are all deemed non-public personal information under GLBA.

2. Does This Meet the Legal Definition of a Breach?

Yes, definitely.

A breach under the GLBA is defined as Unauthorized access to or use of customer information that could cause any customer significant harm or inconvenience.

Given that attackers obtained access without authorization, exfiltration, samples that were posted on their leak site, and Systems that are encrypted.

This satisfies every requirement for a reportable data breach as well as a GLBA security incident.

The majority of state breach laws in the United States define a breach as Unauthorized individuals obtaining personal information that compromises confidentiality, security, or integrity.

Exfiltration plus confirmation of the leak equals a breach that needs to be reported in all 50 states.

3. Notification Obligations & Timelines

Federal GLBA credit unions are required to notify:

- Affected clients
- NCUA, the primary regulator
- Law enforcement (USSS/FBI)

Timeline:

- as quickly as possible.
- For clients, no later than 30 days in practice
- Within 72 hours of determining that misuse has occurred or is likely to occur, notify NCUA.



State Breach Notification Laws

The majority of states mandate:

- Notification within 30 to 45 days
- quicker if financial information and SSNs were compromised
- State Attorneys General must be notified in certain states.

Credit Bureaus

All three credit bureaus need to be informed because over 500 people were impacted

- Equifax
- Experian
- TransUnion

Law Enforcement

It is required because Ransomware, Data fraud, and Criminal activity between states are involved.

The FBI Cyber Division and Electronic Crimes Task Force of the US Secret Service need to be informed.

Members

Notification needs to contain:

- Type of breach
- Exposed data
- Suggested precautions
- Offer for credit monitoring
- Instructions for fraud alerts

The Notification must be sent by email or postal mail, openly on the website if there are more than 500 members

14. Eradication Strategy

Do you agree with the forensic team's recommendation for a full network rebuild?



Yes. Given the size, confirmed findings of multiple backdoors, compromised domain admin credentials, long dwell time, and confirmed data exfiltration, rebuilding the network is the safest and most defensible option.

➤ **Can We Safely Eradicate Without a Full Rebuild?**

- Ransomware has encrypted servers AND destroyed backups
- Forensics indicate lateral movement through domain controllers.
- Admin credentials were compromised
- Persistence mechanisms are likely deployed
- They **exfiltrated 340GB of data**, showing sophistication and long-term access.
- Rootkits or hidden scheduled tasks may remain
- Attackers exfiltrated data for weeks, unnoticed
- Targeted cleanup would not guarantee full eradication.

Anything that isn't a rebuild runs the risk of Reinfection, concealed backdoors, Continuous access, Future attempts at extortion.

➤ **Estimated Timeline & Cost: Rebuild vs Targeted Remediation**

- **Option A:** Full Network Rebuild (Recommended)

Estimated Cost:

\$400,000 for new build, consultants, hardening

\$300,000 for temporary infrastructure and business continuity

Total: \$700,000

Estimated Timeline is 14–21 days for complete rebuild

Critical services restored in 3-5 days through temporary systems

It includes:

- New Active Directory
- New network segmentation
- Clean OS images
- Hardened configurations
- rebuilt file servers
- Recovered clean data from offline backups



- New EDR, MFA enforcement, and PAM
- **Option B:** Targeted Remediation, Try to clean existing systems

Cost Estimate:

200,000 - 350,000 dollars for forensics, cleanup, staff time

Estimated Timeline is 5-7 days Cleaning visible artifacts

Continuous 30-60 days monitoring, patching and validation

The Risks are:

- Hidden persistence mechanisms might remain
- Compromised credentials may reinstate the risk
- Re-infection may occur weeks later on.
- Authorities might find it inadequate in light of severity

➤ **Business Impact of Each Approach**

- **Full Rebuild**

Advantages

- high security assurance
- eliminates all persistence of the attacker
- Regulators support this strategy
- lowers the risk of future cyberattacks
- enhances the general security posture

Disadvantages

- Extended downtime
- Increased immediate expenses
- More personnel resources are needed.

- **Targeted Remediation**

Advantages



- Faster short-term restoration
- Lower initial cost
- Less operational disruption early

Disadvantages

- High risk of reinfection
- Lower regulator confidence
- Attackers may still have foothold
- Reputation & compliance risk increases.

➤ **Risk of Reinfection**

Full Rebuild

- Complete Rebuild Reinfection Risk is Minimal
- Clear AD
- Clean servers and endpoints
- Every credential has been reset.
- New security measures
- Backdoors removed

For a breach of this severity, regulators favor this strategy.

- **Targeted Remediation**

Targeted Remediation: There is a very high risk of reinfection.

Targeted cleanup frequently falls short of eliminating all persistence because there are:

- Unidentified covert remote shells could be used by attackers.
- The admin credentials may still be cached.
- Paths for privilege escalation may still exist.
- The network could be compromised again by a single missed implant.

Many businesses that opt for targeted remediation experience another attack in a matter of months.



15. Recovery Planning

This section outlines a practical, business-aligned recovery strategy following the ransomware incident. The focus is on restoring essential services quickly, ensuring systems are clean before bringing them back online, and establishing a realistic timeline that balances urgency with safety.

➤ Prioritization of Systems for Restoration

Systems should be restored based on business criticality and dependency order:

- Identity infrastructure (Active Directory) – required for authentication across all systems
- Email and communication tools – essential for coordinating incident response and operations
- Member database and core banking interfaces – necessary for serving customers and maintaining financial operations
- File servers and departmental systems – enable internal productivity and documentation
- Workstations – restored in batches once backend services are confirmed clean

➤ Use of 45 Day-Old Backups

In certain cases, older backups can be used, but only when data variance is low or historical updates can be reconstructed. For example, archived documents, HR files, and legacy reports may be safe to restore from 45-day-old backups. However, transactional systems like the member database, loan systems, or finance applications should avoid old backups unless no newer clean restore points exist. Data integrity must outweigh restoration speed.

➤ Validating Clean Systems Before Restoration

Before any system is brought back into production, it must pass a strict validation process:

- Full malware scans using EDR
- Review of system logs for unusual authentication or privilege use
- Integrity checks on critical system files
- Network monitoring for suspicious outbound requests
- Forensic approval confirming no persistence mechanisms remain

➤ Estimated Timeline to Full Operational Recovery

A realistic, staged recovery timeline will look like this

- Hours 0–24: Containment, forensic imaging, initial system isolation
- Days 2–3: Restore AD and core communications



- Days 3–5: Restore member database and critical servers
- Days 5–10: Reimage workstations and restore file servers
- Days 10–21: Full infrastructure rebuild and validation
- Day 30: Final audit, hardening, and return to normal operations

16. Ransom Payment Reconsideration

Given evidence of data exfiltration, the question of ransom payment must be re-evaluated. Attackers claim that paying will prevent public data exposure, but several practical and legal considerations apply.

➤ Likelihood of Attackers Deleting Exfiltrated Data

There is no reliable guarantee that the attackers will delete the stolen data if payment is made. Cybercriminal groups often reuse, resell, or leak data regardless of payment. Payment only reduces the chance of publication; it does not eliminate long-term exposure risk.

➤ Effect of Payment on Breach Notification Requirements

Even if attackers promise to delete the data, this does not affect regulatory obligations. Once exfiltration is confirmed, Finance First is legally required to notify regulators, members, and law enforcement. Payment does NOT remove or reduce GLBA, NCUA, or state-level breach notification requirements.

➤ Cost Comparison: Payment vs. Notification and Recovery

Key cost considerations include:

- Ransom demand: typically, \$1M–\$4M+ for financial institutions
- Data breach notification costs: credit monitoring, legal fees, regulatory compliance
- Long-term remediation: infrastructure rebuild and modernization
- Reputation impact: loss of member trust and commercial clients
- Increased likelihood of repeat targeting if ransom is paid

While paying ransom might seem cheaper in the short term, it rarely reduces the long-term financial impact. Notification, remediation, and legal obligations remain unchanged. Investing in secure recovery and transparency offers better long-term outcome

e

➤ Final Assessment

Base on all available evidence, paying the ransom is not recommended. There is no guarantee of data deletion, regulatory requirements remain unchanged, and long-term recovery costs are similar with or without payment. Efforts should instead focus on secure system restoration, modernization, and strengthening member trust.



17. NCUA Notification

Incident Description and Timeline: We detected a suspected ransomware attack at approximately 9/12/2025 on the System. This discovery led to an immediate isolation of the affected segment. Preliminary analysis indicates a threat actor may have gained unauthorized access and deployed encryption software.

Systems and Data Affected: Our Primary Business System and Member Portal are currently unavailable. Data: We are investigating, but currently suspect unauthorized access to or exposure of credit card data.

Response Actions Taken:

1. **Containment:** Immediately isolated all impacted systems and network segments.
2. **Assessment:** Engaged an external third-party forensic firm to conduct a full investigation.
3. **Mitigation:** Initiated business continuity procedures to restore core services from offline backups.

Estimated Impact and Recovery Timeline:

Impact: Disruption of online banking for an estimated 48 hours. We are running on alternate systems where possible.

Recovery: Full restoration of all affected systems is estimated to be complete by 12/12/2025

Compliance with Notification Timeline Requirements:

Filing Window: The 72-hour clock began at 9/12/2025.

Status: This notification is being submitted at 10/12/2025, which is within the required 72-hour timeframe.

The incident meets SAR filing criteria because the following are true:

- **Unauthorized Transaction Attempt:** The cyber-event involved a known or suspected federal criminal violation, or pattern of criminal violations, and the transaction or attempted transaction involved or aggregated at least \$5,000 in funds or other assets. This threshold applies even if the unauthorized transaction was not successful.
- **Sensitive Data Exposure for Financial Gain:** The cyber-event exposed sensitive customer information that could be used to conduct or affect transactions, and the financial institution reasonably suspects the event targeted this information for the purpose of conducting unauthorized transactions aggregating \$5,000 or more.
- **Insider Abuse:** The incident involved known or suspected insider abuse, regardless of the monetary amount.



- **Ransom Payment:** The attacker is demanding a ransom payment from credit union exceeding \$5,000, which constitute a suspicious transaction to be reported.

Given that a ransomware attack is, by its nature, a crime intended for financial gain, and that a successful intrusion into a financial institution's network often risks customer funds or critical transaction systems, it is highly likely that a SAR filing will be required.

What is the filing deadline?

A SAR must be filed no later than 30 calendar days after the financial institution's initial detection of facts that may constitute a basis for filing a report.

If a suspect is not identified on the date of initial detection, the filing may be delayed for an additional 30 calendar days to identify a suspect, but in no case shall reporting be delayed more than 60 calendar days after the date of such initial detection.

18. Key information that must be included in a SAR for a cyber-event:

The SAR must include all relevant and available information regarding the suspicious transactions and the cyber-event, including a detailed narrative.

- **Cyber-Related Information:** Information that describes technical details of electronic activity, behavior, and the digital footprint of the attackers, including:
 - Internet Protocol (IP) addresses and port information with respective date timestamps.
 - Uniform Resource Locator addresses and Command-and-Control nodes.
 - Attack vectors and methodology.
 - Suspected malware filenames and hash information
 - Email addresses used in the attack.
 - Indicators of Compromise
- **Description of Suspicious Activity:** A detailed narrative describing the cyber-event's type, magnitude, and methodology. This includes what systems and information were targeted, and the aggregate funds or assets involved or put at risk.
- **Categorization:** Selecting all applicable characterization checkboxes in Part II of the SAR, such as Unauthorized Electronic Intrusion.
- **Involved Account Information:** Details of any affected accounts.

19. Member Notification Plan

A comprehensive notification plan must comply with regulatory requirements (e.g., GLBA, state breach laws) and minimize member panic while preserving trust.

Notification Timeline (When to Notify)

Proposed timeline:



- **24 hours:** Internal leadership and Board briefings
- **24–36 hours:** Notification to regulators (NCUA, state authorities)
- **36–48 hours:** Member notification rollout begins

Priority notifications:

- Members with confirmed data exposure
- Commercial accounts and high-value members

Full notification completion: Within 72 hours of confirmation of compromise

Rationale: Balances the need for accuracy in what is disclosed with legal mandates for timely notice, given incomplete forensics.

Notification Methods (How to Notify)

Use a **multi-channel approach** to maximize reach and maintain transparency:

1. **Email** to all affected members
2. **Postal mail** for legally required formal notice and members without email
3. **Dedicated website breach page** with FAQs and updates
4. **Mobile banking app notification banner**
5. **Local media statement** only if necessary (if breach becomes public or regulators require disclosure)

Notification Content (What to Disclose)

Content must be accurate, concise, and non-speculative:

- Summary of the incident (ransomware attack, systems isolated)
- What data **may** have been exposed (pending forensic confirmation)
- Actions taken by the credit union
- Availability of services and expected restoration timelines
- Steps members should take to protect themselves
- Resources provided (credit monitoring, hotline, FAQs)
- Assurance around deposit safety (critical for member confidence)

Tone: Factual, transparent, reassuring, non-technical.

Credit Monitoring & Identity Theft Protection

Provide **24-month credit monitoring**, including:

- Identity theft protection
- Dark-web monitoring
- Fraud alert assistance
- Identity restoration services

Estimated cost: **\$3–5 per member per month**, depending on vendor and membership size.

Call Center Preparation



- Stand up a **dedicated breach response call center**
- Train agents on:
 - The incident summary
 - Impact to accounts
 - FAQs and talking points
 - Escalation paths for high-value members
- Extend operating hours for the next 14 days
- Prepare scripts for:
 - “Is my money safe?”
 - “Was my data leaked?”
 - “When will services be fully restored?”

Estimated staffing:

- 20 additional temporary agents for 14 days.

Estimated Cost of Notification Process

Component	Estimated Cost
Email + postal mail	\$180,000–\$250,000
Credit monitoring	\$500,000–\$1.2M (membership-size dependent)
Call center surge	\$150,000
Website + communication support	\$50,000
Legal/compliance review	\$50,000
Total Estimated Notification Cost	\$930,000 – \$1.65M

20. Law Enforcement Coordination Plan (FBI)**Benefits of FBI Involvement**

- Indicators of compromise (IOCs) to accelerate Containment.
- Threat intelligence about the specific ransomware group
- Assistance with attribution and preserving evidence
- May provide insight on decryption tool availability from prior cases
- Increases credibility with regulators (NCUA expects LE engagement)

Risks of FBI Involvement

- Increased likelihood of media exposure
- Attackers may become hostile if they discover FBI involvement



- FBI will not assist with negotiation or ransom payments
- Could slow internal processes due to evidence handling procedures

Impact on Ransom Payment Decision

- FBI strongly discourages payment
- Their involvement could influence leadership away from paying
- If ransom must be paid, FBI guidance ensures legal compliance (sanctions screening, OFAC risk mitigation)

Evidence Sharing & Coordination Procedures

- Maintain full chain-of-custody logs
- Provide disk images, logs, malware samples to FBI via secure transfer
- Weekly coordination calls with FBI cyber squad
- Continue allowing FBI access but maintain organizational autonomy over business decisions

PHASE 3: RECOVERY AND RESTORATION (HOUR 24-48)**21. Recovery Strategy Recommendation:**

Rebuild and restore from off-network, verified backups (no ransom payment).

Our immediate recommendation is to refuse to pay the ransom and focus on rebuilding critical systems and restoring data from verified, off-network backups. This strategy prioritizes long-term security, legal/ethical compliance, and avoids rewarding criminal behavior, even if it introduces short-term business impact.

Comprehensive Justification**➤ Total Cost Analysis**

Cost Factor	Pay Ransom (75 BTC)	Rebuild & Restore
-------------	---------------------	-------------------



Direct Ransom Payment	\$2.8 million	\$0
Forensics/Negotiation	\$500k - \$1M (Still needed)	\$500k - \$1M (Still needed)
System Rebuild/Remediation	\$500k - \$1M (Needed due to <i>data exfiltration</i>)	\$1M - \$2M (Higher initial effort)
Business Disruption (4-7 days)	\$500k - \$1M	\$1M - \$2M (Higher, but shorter <i>long-term</i>)
Regulatory Fines/Legal	High (Due to data publication threat)	Moderate (Due to incident itself)
Total Estimated Cost (Excl. Fines)	\$4.3M - \$5.8M	\$2.5M - \$5M
Hidden Cost/Risk	Payment is not a guarantee of decryption or non-publication. Risk of being targeted again.	Data loss limited to gap between last clean backup and incident.

➤ Timeline and Business Continuity Considerations

- **Pay Ransom:**

- **Timeline:** Fastest theoretical recovery (1-3 days post payment to receive keys and decrypt)
- **Business Continuity Impact:** High initial downtime, followed by a risky and slow decryption process. Business remains offline until decryption is verified and systems are deemed clean.

- **Rebuild and Restore:**

- **Timeline:** Slower initial recovery (5-7 days) but provides a clean and stable foundation.
- **Business Continuity Impact:** High initial downtime, but recovery is controlled and deterministic. Focus on bringing core banking, online/mobile services, and branch services back online in a phased, prioritized manner.

➤ Risk Assessment for Each Option

Risk Factor	Rebuild and Restore
Data Recovery	Low Risk: Data recovered is from a known, clean source. Only risk is the data gap.
Data	High Risk: The threat actors already claim to have the data.



Exfiltration/Publication	Payment doesn't mitigate this.
Reputation/Future attacks	Low Risk: Strengthens the organization's posture and provides a clean slate.
Legal/Ethics	Low Risk: Adheres to best practice and law enforcement recommendations.

➤ **Long-Term Security Implications**

- **Pay Ransom:** Zero long-term security gain. The root cause (initial breach) is unaddressed, and the organization remains vulnerable. Decrypted systems are still contaminated.
- **Rebuild and Restore:** Results to massive security gains like lean rebuild of the environment, allowing for mandatory security hardening, multi-factor authentication and application white-listing. It also eradicates every trace of the attacker before recovery.

➤ **Regulatory and Legal Considerations (NCUA, FFIEC, GLBA)**

- **Legal Duty:** GLBA requires protection of customers data. Since the attacker claims to have exfiltrated member data (SSNs, account numbers) a data breach notification is highly likely regardless of the recovery path chosen.
- **NCUA/FFIEC:** Regulators expect due diligence and adherence to best practices, which generally advise against paying the ransom. They require robust Business Continuity/Disaster Recovery plans, which this option demonstrates.
- **Chain of Custody:** The building and restore allows the Incident Response team to take clean, forensically sound images before wiping/rebuilding, ensuring better chain of custody for legal proceedings. Paying the ransom complicates the crime scene.

➤ **Recommendation: Detailed Implementation Plan**

This plan assumes a clean, segregated backup repository exists (a critical, immediate action is to verify this).

Phase A: Prioritized Recovery (Rebuild & Restore)

Step	Action	Justification/Priority
------	--------	------------------------



A-1	System categorization and Prioritization. Identify all affected systems and categorize them (Mission-Critical, High-priority, Standard). Mission-Critical: Core Banking System, Member Authentication/Portal, Payment Gateways.	Essential for a phased recovery; focus limited resources.
A-2	Build Clean Environment. Deploy new, patched operating systems and functional infrastructure for Mission-Critical systems on a completely segregated network segment.	Ensure a secure, non-compromised base
A-3	Data Restoration. Restore data from the most recent, verified clean, off-network/immutable backups to the new server	Focus on data integrity and non-reinfection.
A-4	Data Integrity check. Run comprehensive integrity and malware scans on restored data and test application functionality before reconnecting to the broader network or users.	Critical step to prevent re-infection and ensure business continuity.
A-5	Phased Go-Live. Restore member-facing service first with a security-first approach	Re-establish customer trust and essential business operations.

Phase B: Supporting and Long-Term Actions

- Containment: The initial response should already have been to disconnect all compromised network segments and isolate the core banking system from the intern and corporate network.
- Forensics: Continue the forensic investigation in parallel to identify the Initial Access Vector (IAV) and the full extent of the data exfiltration claim.
- Communicate: Prepare and execute the breach notification plan immediately, engaging legal and communications teams to inform members and regulators transparently truthfully.
- Funding: Use the \$50,000 budget authority to immediately engage a specialist third-party ransomware negotiation/response firm and a legal counsel experienced in financial services data breaches to manage the external communication and evidence handling.

22. Executive Briefing: Urgent Ransomware Incident at Finance First Credit Union

➤ Current Situation Summary

At approximately 6:45 Am this morning, our security monitoring systems detected widespread, unauthorized file encryption activity across multiple file servers, confirmed to be a Ransomware Attack. The core banking system's availability is currently impacted.



- **Impact:** Files, documents, and critically, the attacker claims to have encrypted our backup systems and exfiltrated a comprehensive set of member data, including names, SSNs, accounts numbers, balances, and employee records.
- **Attackers:** An unknown group (likely a well-organized enterprise).
- **Demand:** The attackers demand 75 Bitcoin (\$2.8 million USD), with a 72-hour deadline. Failure to pay will result in the ransom doubling and the public release of all stolen member data on the dark web.
- **Current Status (Containment):** The CSIRT team has initiated emergency shutdown and network segmentation procedures to stop the encryption spread. Forensic investigation is beginning to confirm the attacker's claims and determine the initial access vector.

➤ **Recovery Options Analysis**

Two primary paths are available. Our decision hinges on balancing immediate business continuity against long-term security and regulatory risk.

Option	Pros	Cons
Option A: Pay the Ransom	1. Potentially Fastest Recovery: Could restore files within 2-3 days if the decryption key works. 2. Avoids Data Publication: (Uncertain) May encourage the attacker not to publish stolen data.	1. High Direct Cost: \$2.8 million (75 BTC). 2. No Guarantee: Keys often fail, and the attacker may still publish the data leading to more extortion risk. 3. High Re-targeting Risk: Identifies FinanceFirst as a payer. 4. No cleanse: Leaves the threat actor's access vector in place, requiring a full rebuild anyway.
Option B: Rebuild & Restore from Clean Backups	1. Guaranteed Clean Environment: Ensures the attacker is completely eradicated. 2. Avoids Funding Criminals: Adheres to regulatory/law enforcement guidance. 3. Legal-Term Security: Allows up to implement immediate security upgrades (MFA, Zero Trust segmentation) during the rebuild.	1. Slower Recovery: Estimated 5-7 days for mission-critical systems. 2. Higher Initial Business Impact: Extended downtime for some services. 3. Guaranteed Data Exfiltration Notification: Must notify members, as why payment is not made to secure the data.



	4. Fixed Cost: Avoids the \$2.8M ransom payment.	
--	--	--

➤ **Recommendation, Rationale, Expected Outcomes**

Recommendation: Opt for Rebuild and Restore (OPTION B)

Rational:

- Integrity over speed: Paying the ransom offers only a fragile, unverified path to recovery and does not address the security flaws that enabled the breach. Our fiduciary duty to our members requires a secure, clean environment.
- Exfiltration Risk: The attacker has already claimed to have the member's data. Paying the ransom is unlikely to prevent publication, as this separate, more lucrative extortion tactic. We must operate under the assumption that a data breach notification is required regardless of payment.
- Regulatory Compliance: Regulators (NCUA, FFIEC) require Disaster Recovery plans. Executing our plan and refusing to fund criminal enterprise demonstrates due diligence and commitment to security best practices.

➤ **Expected Timeline and Cost (Option B – Best Case Scenario)**

Category	Timeframe	Estimated Financial Impact (Excluding Fines)
Containment/Eradication	24- 48 hours	\$ 0 (Internal Teams)
System Rebuild & Validation	3- 5 days	\$500k - \$1M (Forensics, External Consultants, Emergency Licensing)
Data Restoration	5 – 7 days (Total Outage)	\$1M - \$2M (Estimated Business Disruption/Lost Revenue)
Total Incident Response Phase	~ 7 days	\$1.5M - \$3M
Regulatory Risk	Ongoing	High (likely multi-million-dollar regulatory fines and legal costs due to data exfiltration)

1. Long-Term Implications and Lessons Learned

Long-Term Implications:

- Guaranteed Data Breach: We must prepare for a full-scale member notification campaign, credit monitoring offers, and regulatory reporting as required by GLBA and FFIEC.
- System Hardening: This incident will force an immediate, organization-wide investment in security controls, including mandating MFA, implementing Zero Trust network segmentation and improving backup immutability.

**Immediate Action (Next 24 Hours):**

1. External Expertise: Immediately engage specialist legal counsel and a top-tier forensic firm
2. Stakeholder Communication: General Counsel and the CCO must finalize internal and external communications regarding system outages and potential data exfiltration.
3. Recovery Focus: The CSIRT team is fully dedicated to verifying clean backups and beginning the phased rebuild of the core banking system.

23. Implementation Plan

This implementation plan is based on the chosen recovery strategy: Hybrid Approach

1. Phase-by-Phase Restoration Sequence

- Phase 1: Immediate Stabilization (Hour 0–12)
 - Keep all infected systems offline and isolated
 - Disable all compromised accounts and reset all privileged credentials
 - Block malicious IP addresses and command-and-control traffic
 - Secure backups and cloud systems
 - Begin ransom negotiation solely for decryption key retrieval
 - Preserve evidence for law enforcement and regulators
 - Outcome: No further spread, environment stabilized
- Phase 2: Critical System Decryption and Temporary Restoration (Hour 12–48)
 - Receive and test decryption keys from attackers
 - Decrypt core internal systems, customer service systems, loan processing platforms
 - Restore cloud email from intact backups
 - Apply emergency security patches
 - Resume minimum essential operations
 - Outcome: Business partially restored within 48 hours
- Phase 3: Parallel Full Network Rebuild (Day 2–Day 21)
 - Build new clean infrastructure
 - Implement network segmentation, Privileged Access Management (PAM), MFA for all users
 - Deploy new firewalls, Endpoint Detection and Response (EDR), SIEM monitoring
 - Migrate clean data only to new network
 - Decommission all old infected systems
 - Outcome: Attack-free environment achieved



- Phase 4: Validation and Testing (Day 15–Day 21)
 - Vulnerability scanning
 - Penetration testing
 - Malware scans
 - Transaction integrity checks
 - User acceptance testing (UAT)
 - Outcome: Systems certified safe for full production use
- Phase 5: Full Operational Recovery (After Day 21)
 - Resume all customer services
 - Reopen all digital and branch services fully
 - Conduct post-incident review
 - Update IR and BC/DR plans
 - Outcome: Normal operations permanently restored

2. Resource Requirements

- Personnel
 - Cyber Incident Response Team
 - External Forensic Experts
 - Network & System Engineers
 - Legal & Compliance Officers
 - Public Relations & Communications Team
 - Call Center Surge Team
 - Cybersecurity Vendors
- Equipment and Technology
 - New servers and network hardware
 - Endpoint Detection and Response (EDR)
 - SIEM systems
 - Secure backup servers
 - Privileged Access Management system
 - MFA tools

- Budget (Estimated)

Item	Estimated Cost
------	----------------



Ransom Payment and Negotiation	\$2.1M
Full Network Rebuild	\$400,000
Temporary Infrastructure	\$300,000
Forensic and Security Consultants	\$150,000
Member Support and Credit Monitoring	\$400,000
PR, Legal and Regulatory Costs	\$250,000
Total Estimated Cost	\$3.6M – \$3.8M

3. Validation and Testing Procedures

- Integrity testing of restored databases
 - End-to-end transaction verification
 - Independent third-party penetration testing
 - Access control reviews
 - Continuous monitoring through SIEM
 - Daily security audits for first 30 days
- Rollback Procedures (If Issues Arise)
- Maintain immutable backups at every restoration stage
 - If reinfection is detected:
 - Immediately isolate affected system
 - Revert to last known clean backup
 - Re-scan before redeployment
 - Stop migration if malware signature is found
 - Full forensic re-analysis before proceeding

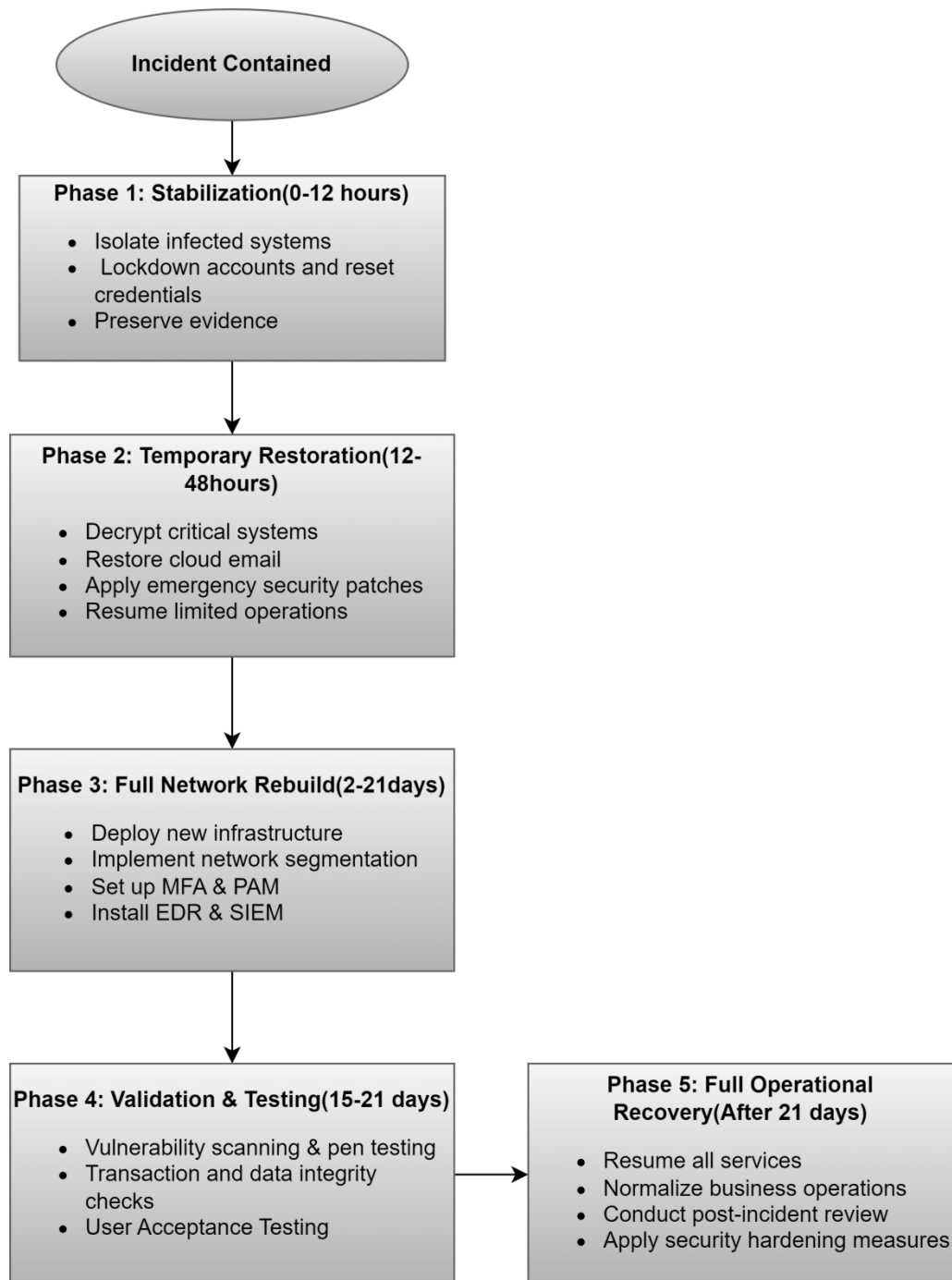


➤ Communication Plan for Stakeholders

Stakeholder	Method	Frequency	Responsible
Board of Directors	Executive Briefings	Daily	CEO, CISO
Regulators (NCUA, State)	Formal Reports	As Required (24–72 hrs)	Legal and Compliance
Members	Email, SMS, Website	Daily Updates	Communications
Employees	Internal Emails and Meetings	Twice Daily	HR and Executives
Media	Press Releases	As Events Occur	Communications Officer
Law Enforcement	Secure Coordination	Continuous	General Counsel



Recovery Timeline Diagram



24. CRISIS COMMUNICATION RESPONSE

➤ Public statement for Media & Website

Draft Statement



A security problem impacting TechMed Solutions was just discovered by us. Our security team started our incident response procedure as soon as we noticed odd behavior in order to contain the problem and safeguard our systems.

We are limiting the facts for the time being because our investigation is still ongoing, but we can assure you that our teams and outside security specialist are working nonstop to completely comprehend what transpired and guarantee the protection of our systems.

We take our clients privacy and security extremely seriously, and we'll keep you informed as we find out more. We shall directly notify any affected parties and take all necessary legal action if we can verify that any sensitive or personal information was compromised.

➤ **Member Notification Letter**

Subject: Important Notice About Your Personal Information

Dear Esteemed Member,

We are writing to let you know about a recent TechMed Solutions security incident that might have compromised some of your personal data. We secured the impacted systems as soon as we discovered the problem and, with the help of cybersecurity specialists, we started a thorough investigation. We think that some personally identifiable information may have been at this point.

Although there isn't any proof of misuse at this time, we are informing you out of duty and transparency, so you can take precautions.

We provide:

- Free credit/identity monitoring
- A dedicated help line to address your inquiries

We really regret any worry this may have caused. We take our obligation to protect your information seriously, and in order to avoid similar events in the future, we are bolstering our security measures.

Sincerely,
Finance First Credit Union Security Team.

➤ **Internal Employee Communication**

Draft Internal Message

Team,

I would like to inform everyone that we are currently addressing a security incident that involves a portion of our surroundings. The impacted systems have already been confined by the CSIRT, and our legal, communications, and IT teams are supporting our ongoing investigation.



Please refrain from disclosing any information to third parties, such as partners, clients, or social media. To guarantee accuracy and consistency, all external communications will be managed by the communications and Leadership teams.

Customers and Partners can contact you at +34528923457 if they have any questions.

We'll keep you informed as the inquiry develops.

I appreciate your cooperation and expertise.

➤ **Talking Points for executives and call center staff**

What we know:

- We detected unusual activity and immediately activated our incident response plan
- The affected system was isolated quickly to prevent further impact
- A full investigation is ongoing with internal and external experts

What we can say publicly:

- We take this seriously and are prioritizing transparency
- If any customer data was impacted, we will notify them directly
- We are following all legal and regulatory requirements

What we cannot share yet:

- Technical details of the attack
- Specific system names or internal controls
- Unverified information

Tone reminders:

- Stay calm and factual
- Avoid assigning blame
- Avoid speculating
- Always redirect detailed questions to the communications team.

24. Damage Control Strategy

➤ **Immediate support for Affected Members**

Priority is taking care of the people impacted. Anyone affected will immediately get:

- Free credit monitoring and identity-theft protection
- Guidance on placing fraud alerts and credit freezes
- Extra account monitoring and fast-track support for any suspicious activity

The major goal is simple: make sure members feel protected and supported right away.

➤ **Media Management Strategy**

For the public side, the messaging must stay consistent and controlled

- Communications will handle all media inquiries



- If necessary, we'll hold a short press briefing to address the situation clearly
- Social media responses will stay factual, calm, and focused on what we're doing to fix the issue.

The tone everywhere remains the same: transparent, responsible, and focused on solutions.

➤ **Member Relation Initiatives**

We need to reassure members that staying with us is still in their best interest. Some steps include:

- Waiving certain fees for affected members
- Rolling out enhanced security features (Stronger authentication, real-time alerts etc)
- Having our relationship managers reach out to high-impact groups personally.

The message is: *we value you, and we're committed to earning your trust back.*

➤ **Regulatory Coordination**

Finally, in order to stay ahead without being called first;

- We'll proactively reach out to NCUA (National Credit Union Association) and relevant state regulators.
- Provide them with early details, even if still preliminary
- Share ongoing updates as we learn more

This shows accountability and helps avoid compliance issues later.

25. Ransom Payment Reconsideration Update

The attackers are offering a "final chance" to pay \$3.5 million (increased from \$2.8M) to receive decryption keys and prevent publication of the remaining 84,500-member records.

Here is our professional and honest recommendation on this new development:

- There is no credible reason that exists to trust that payment would halt further data publication of the remaining records. Ransomware groups such as REvil employs double extortion tactics, where exfiltrated data is retained as leverage after payment. Payment provides no enforceable guarantee, no legal contract, no technical verification that the attacker will delete the stolen data. The price increase from 2.8M to 3.5M shows the group are opportunist and do not have the wellbeing of the organization at heart. This aligns with FBI and CISA guidance, which emphasized that payments prevent no reliable recovery assurance, funds criminal operations, and do not mitigate long-term risks. Paying the ransom only accelerates the system restoration, but does not eliminate breach notification requirements or risk of reinfection and future publications.
- Payment only provided very limited value at this point given partial publication of sensitive data. Decryption keys may restore some systems, but the forensic team already recommended full network rebuild, making decryption less relevant. Even if the data is decrypted using the decryption key provided, there may be left traces of the ransomware, that may be used again to cause the same attack and ask for ransom



again. The data breach has already occurred publicly, triggering unavoidable regulatory notifications. The 500 records already leaked includes SSNs, account numbers, balances, which meets GLBA's breach definition, mandating immediate notification to the affected members. Payment cannot reverse regulatory and legal obligations

- Message Payment of Ransom fee send to members, regulators, and future attackers
 - **To members:** Shows weak cybersecurity posture within the organization, suggest that the organization can be easily extorted, show weak leadership and poor decision making. erodes trust.
 - **Regulators:** Non-compliance with federal guidance from FBI and CISA, the regulatory would question the risk management technique, on why the organization used \$35M on a risky transaction with no guarantee, and send a message of failure to address the root cause for full eradication.
 - **Future attackers:** the company will be put at a target list as a willing payer, increasing the likelihood for future attacks. Validate the attacker's double extortion business model as every payment encourages the attackers to continue and escalate their activities.

➤ **Better uses of funds**

The funds could be redirected to cover the inevitable and mandatory costs associated with this data breach. This includes;

- a. Complete rebuild of the network which needs \$400,000 and \$300,000 for temporary rebuilding the infrastructure.
- b. The amount could also be used for cost associated with breach notification.
- c. Long-term security improvement: The remaining funds could have been proactively invested in rectifying the severe gaps identified in the Lesson Learned part of the incident response. This investment includes
 - network segmentation- implementing stronger separations to prevent future lateral movement.
 - Privileged Access Management solutions (PAM) to control and monitor the domain administrator credentials that were compromised
 - Immutable. Air-gapped backup that ensure backup server is logically or physically separated from production network to prevent future backup encryption
 - Enhanced detection capabilities.

26. Legal and Regulatory Strategy

- Work with General Counsel to develop strategy for:
 - Regulatory notifications and coordination (NCUA, state banking regulators, state attorneys general)



- NCUA notification: the organization must ensure it complies with the 72-hour timeline for reportable cyber incidents, which the NCUA examiner has already referenced. This communication needs to be proactive, detailing the confirmed data exfiltration and subsequent public leak.
- GLBA Member notification: The requirement under GLBA is to notify affected members “as soon as possible” after discovery of unauthorized access. Given the public posting, the notification is now urgent. The legal team must immediately finalize the notification content and process
- State regulators/attorney general: Since the credit union serves members across multiple states, state breach notification laws apply with timelines ranging from “without reasonable doubt” to specific deadlines, typically 30-45 days. Several states require notification to the attorney general if >500 residents are affected, a sample copy of the notification letter, and remediation steps and credit monitoring details.
- Credit Bureaus: because SSNs and financial data were exposed, Equifax, Experian, and Transunion must be notified if more than 1000 individuals are affected in a single state.
- FinCEN (Suspicious Activity Report: A cyber-related SAR is required because the incident involves possible extortion, attempted theft and fraud. Members’ accounts were stolen, ransomware amount exceeds the \$5000 SAR threshold.
- Coordination Strategy
Lead: General Counsel, with CSIRT input.

Actions: escalate NCUA report with leak details by EOD, host joint call with state regulators, share forensic IOCs to demonstrate diligence.

Risk/ Mitigation: Delayed notice could trigger \$100K and fines.

- Law enforcement coordination (FBI, Secret Service, state law enforcement)

Agency	Role	Coordination mechanism	Actions/Timeline
FBI Cyber Division	Lead on ransomware investigation, Provide IOCs, Victim support via IC3, Advises against payment.	Report via IC3 portal, share logs/forensics, joint ops for takedowns	Immediately share leak site evidence today. BI-weekly intel briefings starting the day of detection.
U.S Secret Service	Focuses on financial cybercrime, arrests for violations of	Evidence sharing for collaboration	Initial outreach, provide transaction logs for tracing



	wire fraud statutes.		exfiltration.
State Law enforcement	Local support for member fraud probes, AG coordination	Share SAR data	Notify immediately if state specific victims >1000, Joint task force if class action emerge

Coordination Strategy:

Lead: CSIRT with FBI point-of-contact

Actions: Submit updated IC3 report with dark web screenshots by EOD, request urgent leak site monitoring, preserve chain-of-custody for all evidence.

- Potential litigation defense (class actions, regulatory enforcement)

1. Class Action Lawsuits

Members may sue for:

- Negligence
- Failure to safeguard data
- Delayed notification
- Emotional distress and financial harm

Actions:

- A. Engage external breach litigation counsel
- B. Begin preparing defensible documentation of
 - Detection, response steps, timelines
 - Forensic findings
 - Notification reasoning
 - Decision-making frameworks

2. Regulatory requirement

Potential investigation from:

- NCUA
- CFPB
- State Attorney General

3. Board & Executive liability

Review D&O insurance applicable for:

- Claims of governance failures



- Breach of fiduciary duty
- Negligence in oversight
- Insurance claims (cyber insurance, D&O insurance)

PHASE 4: POST-INCIDENT ACTIVITY (HOUR 48-72)

27. Root Cause Analysis using the Five Whys

Problem Statement:

Why the ransomware happened and why it succeeded?

Why 1: Why did the ransomware attack succeed?

Because a phishing email was successfully delivered, opened by an employee, and the malicious attachment executed, leading to malware installation and eventual ransomware deployment.

Why 2: Why was the phishing email successful?

Because existing email security controls and user awareness measures were not sufficient to prevent a convincing phishing message from bypassing defenses and being acted upon.

Why 3: Why were the controls and awareness insufficient?

Security awareness training was generic, infrequent, and not reinforced through realistic phishing simulations. At the same time, technical controls such as advanced email filtering and behavioral detection were limited in effectiveness.

Why 4: Why was training were attackers able to remain undetected for three weeks and move laterally?

Because the network lacked proper segmentation, privileged access management was weak, and monitoring tools were not tuned to detect low-and-slow attacker behavior such as credential harvesting and reconnaissance.

Why 5: Why did these systemic weaknesses exist?

Because incident response and cybersecurity investments were treated as compliance-driven rather than risk-driven. The incident response plan existed on paper but had never been tested, and security architecture improvements were deferred in favor of operational convenience and cost savings.

In Summary, the ransomware attack did not succeed because of a single employee mistake. It succeeded due to systemic weaknesses across people, process, and technology, including inadequate phishing resilience, weak credential controls, insufficient detection capability, lack of network segmentation, and an untested incident response program.

28. Lessons Learned Documentation



Incident Timeline and Key Events (Summary)

Nov 10: Phishing email delivered and malicious macro executed

Nov 11–17: Lateral movement and credential harvesting undetected

Nov 18: Domain administrator credentials compromised

Nov 19–Dec 1: Sensitive data exfiltrated over an extended period

Dec 1 (Early Morning): Backup systems encrypted

Dec 1 (6:25 AM): Widespread ransomware encryption detected

Dec 1 onward: Containment, forensic investigation, and recovery initiated

What Worked Well (Practices to Sustain)

- Network isolation of core banking systems prevented full operational shutdown and allowed basic services to continue.
- Rapid containment actions, once the incident was detected, stopped further encryption.
- Executive support and decision authority enabled swift engagement of external forensic expertise.
- Detailed documentation and logging supported regulatory reporting and legal defensibility.
- Cloud-hosted services' resilience ensured online and mobile banking remained available.

What Did Not Work Well? Areas for Improvement

- Phishing defenses and user awareness failed to prevent initial compromise.
- Detection capabilities were insufficient, allowing a three-week attacker dwell time.
- Privileged access controls were weak, enabling domain-level compromise.
- Backup strategy lacked immutability and network isolation, rendering backups unusable.
- Incident response plan execution was inconsistent due to lack of testing and role clarity.

Specific Recommendations for Improvement

Area	Recommendation	Responsible Party	Timeline
Phishing Defense	Implement advanced email filtering and continuous phishing simulations	CISO / IT Security	0–3 months
User	Move to role-based, scenario-driven	HR / Security	1–3



Awareness	security training		months
Detection	Enhance SIEM and EDR tuning for behavioral threats	SOC Manager	1–6 months
Privileged Access	Deploy Privileged Access Management (PAM) solution	IT Security	3–6 months
Network Design	Implement strict network segmentation	Infrastructure Team	3–9 months
Backups	Deploy immutable, offline, and regularly tested backups	IT Operations	1–6 months
IR Readiness	Conduct regular tabletop and live incident response exercises	IR Manager	Ongoing

Responsible Parties and Implementation Timelines

- **Immediate (0–30 days):**
IR plan update, phishing simulations, regulator-aligned notification playbooks
- **Short Term (1–6 months):**
PAM deployment, SIEM improvements, backup redesign
- **Long Term (6–12 months):**
Network architecture overhaul, maturity-driven security investments, recurring IR drills

Key Takeaway

What this incident really showed is that resilience is not built during an attack. It is built months before one happens. The organization did some things right under pressure, but the damage occurred long before encryption began. The focus going forward must shift from reacting to incidents to reducing the likelihood and blast radius when they inevitably occur.

29. Improvement Recommendations

People and Process: Beyond technical issues, the REvil ransomware incident at FinanceFirst reveals significant flaws in user behavior, security culture, and the usefulness of the Incident Response (IR) framework. On paper, there was an IR plan and basic training, but they were not adequately implemented or tested in real-world situations. When the crisis struck, employees continued to fall for a phishing email, suspicious activity went unnoticed for weeks, and roles, responsibilities, and decision-making were unclear. As a result, this section offers top-priority suggestions for improvement in two crucial areas: Process (Policies and Procedures) and People (Training and Awareness).

People: Training and Awareness



From the incident scenario, below are the training gaps identified:

- Social engineering and phishing are not very resilient.
Despite receiving training, the employee continued to enable content and open a malicious attachment. This implies that employees lack the necessary skills to identify and react to sophisticated phishing emails, especially those with lures related to finance or human resources.
- Reporting suspicious activity is not given enough attention.
Before being discovered, the attacker had been active in the environment for about three weeks. This suggests that staff members either didn't know what abnormalities to look for or weren't sure how or where to promptly report them.
- Roles and responsibilities in incident response are not well understood.
IT, management, and executives were unsure of who should approve shutdowns, notifications, or interactions with outside parties during the incident. This demonstrates that senior stakeholders and the IR team had not received sufficient training regarding the IR plan and their respective roles within it.
- Absence of practical exercises and practice.
There had been no significant testing of the current IR plan through drills or simulations. As a result, rather than carrying out prepared actions during the crisis, staff members were reading the plan.

30. Process: Policies and Procedures

Currently, the incident response (IR) plan will need to be updated and made more practical in the day-to-day use. The following are recommended for improvement.

- **Restore and align the IR with the best practices (short)**

The IR plan should be studied and reviewed to be sure it clearly follows recognized IR phases:

This includes the preparation, detection, eradication, containment and recovery, and post-incident review. It should explain incident severity levels with a clear escalation pathway and decision yardstick at each level.

- **Establish scenario-based playbooks (short term)**

Implement practical playbooks for the high-risk scenarios like ransomware and data exfiltration. And, each of these playbooks should set out step-by-step actions, checklists and standard communication templates that cover both internal and external stakeholders.

- **Place legal, regulatory and communication prerequisites (short-medium term).**

A simple process plan should be put in place for assessing regulatory notice thresholds, identifying who drafts and approves external communications, and stating when to bring in law enforcement, regulators or other third parties.

- **Connect incident response with business continuity and disaster recovery (medium term)** it should be certain that IR plan is fully aligned with business continuity plan



(BCP) and disaster recovery (DR) plans. And this should include agreed RTOs for highly critical systems and a plain description of how recovery activities will be organized with security, operations and compliance teams.

New policies and procedures: FinanceFirst should implement or improve these following policies and procedures;

Ransomware and cyber extortion policy.

Clarify the organization's viewpoint on ransom payments, approval levels eg, executive committee, board of directors) and documentation prerequisite for any decision taken.

Privileged access protocols

Outline how privileged accounts are created, used, monitored and annulled.

Necessitate multi-factor authentication and regular access reviews.

Backup and recovery procedures.

Explain backup rate, retention and testing prerequisites, with focus on secure, tamper-resistant backups suitable for ransomware recovery.

External support engagement procedures.

State how and when to engage external forensic/incident response providers, cyber liability insurers, law enforcement, backed by amended contact lists and contracts.

Clarifying decision-making authority

In conclusion, decision-making authority during incidents must be understood:

- An incident command structure should be created (short term)
- Assign an incident commander e.g. (CISO) and the outline supporting roles like operations. Legal and Compliance, Communications and Business continuity leads.

Develop an IR governance charter and RACI (short term).

- Outline which decisions can be taken at operational level, which needs executive approval and which requires Board participation e.g. (ransom payments etc.). Use of RACI matrix should be adopted for key activities like isolation, notifications and public statements.

Formalize escalation and communication routes (medium term).

- Record escalation steps from programmed routine to full conflicts and state how and how often the Board, regulators and key stakeholders are briefed.

31. Technology (Security Controls):

What technical security improvements are needed?



- Defense-in-depth strategy will have to be employed, where multiple layers of security will have to be applied to prevent an attacker from easily gaining access to the company's infrastructure in the event of a phishing success.
- Deploying multifactor authentication adds an extra layer of defense,
- Deploying Privileged Access Solutions (PAM). The PAM solution must have capabilities to support the policies you establish, such as automated password management and multifactor authentication, and administrators should have the ability to automate the process of creating, amending, and deleting accounts. Your PAM solution should also continuously monitor sessions so you can generate reports to identify and investigate anomalies.
- SIEM rules and policy should be revised to ensure early detection and a trigger to alert the CSIRT team of a security breach.
- Network Segmentation should be enforced, and the backup server should not be on the same network as the production network.
- Backup servers should be properly encrypted, and immutable backups implemented.

What detection and response capabilities should be enhanced?

- SIEM rules and capabilities should be enhanced to detect and alert for lateral movement and the use of privileged accounts on non-admin systems.
- SIEM rules should also be upgraded and applied to the Production server for intrusion detection and alerting the CSIRT team.

What backup and recovery improvements are required?

- The backup server should be isolated from the production network.
- An immutable backup should be implemented, as it will help to ensure the integrity of the data on the backup server, and the policy will ensure that backups cannot be altered or deleted for a set period.

32. Metrics and Measurement - Propose key performance indicators (KPIs) to measure incident response effectiveness going forward:

- **Mean Time to Detect (MTTD):** It measures the effectiveness of improved monitoring, EDR, and user reporting. The target will be to reduce the detection time to less than 4 days.



- **Mean Time to Respond (MTTR):** It measures IR team readiness and process efficiency. The target will be to reduce the response time from alert to initial containment to less than 5 hours.
- **Mean Time to Contain (MTTC):** It measures the time it will take the team to contain the system from further attack. The target for the containment time should be less than 3 hours.
- **Mean Time to Recover (MTTR):** It measures the amount of time it takes the IR team to get an affected system back up and running again. This should be done based on the criticality and severity of the system or infrastructure affected. Recovery time should be less than 3 days.
- **Incident response plan testing frequency:** Tabletop exercises should be carried out once in two months. Full Incident Response simulations should be carried out twice a year.
- **Security awareness training effectiveness:** Phishing simulation click rate should be less than 5%.



33. EXECUTIVE SUMMARY

Finance First Credit Union was the target of a serious ransomware and data-exfiltration attack on December 1 2025 at 6:45 AM. A staff of Finance First innocently opened a malicious attachment from a phishing email on November 10th which is when the intrusion started. After gaining covert domain administrator access, the attacker, who was later identified as a member of the REvil/Sodinokibi group, moved secretly within company's network for almost three weeks exfiltrated about 340GB of sensitive member data and installed ransomware that encrypted file servers and on-premises backup systems.

The attackers demanded a ransom fee of 75 Bitcoin or about \$2. 8 million in order to prevent the data from being published. The company refusing to pay, started a controlled rebuild using verified off-network backups right away after conferring with the leadership, the Incident Response Team and legal counsel.

Operations finances and reputation were all severely impacted by the incident. Payroll, account opening and loan processing were among the crucial administrative services that were unavailable for a week. It was necessary to manually reconcile six weeks' worth of transactions due to the use of out-of-date backups from 45 days ago.

A verified GLBA data breach that revealed names, Social Security numbers, account information and balances impacted all 85000 members. Over \$2.5 million has already been spent on remediation and forensic investigations not including any potential legal or regulatory penalties. Attacker's publication of 500 member records on the dark web exacerbated the situation and resulted in mandatory public and regulatory notices as well as a significant drop in member trust. The NIST incident lifecycle was followed in the responding to the security event.

The CSIRT was activated after the incident was determined to be critical. The Core Banking System was shielded from ransomware infection by segmenting compromised admin subnets. The company used secure offsite tape backups to restore services wiped and reimaged all impacted systems and ordered a worldwide password reset. Within seven days core operations were resumed and a complete recovery is expected in 21 days. All necessary notifications to the FBI NCUA state regulators FinCEN and members have been fulfilled. Critical operation systems currently operate on an isolated recently rebuilt infrastructure and full data reconciliation is underway.

All privileged accounts must now use multi-factor authentication and the development of a Privileged Access Management System is being accelerated. While regulatory reviews are underway litigation counsel is getting ready for potential class-action lawsuits.

Major security flaws were exposed by the incident including extended attacker presence due to detection gaps, inadequate access controls that allowed privilege escalation from a single phishing attack, a lack of immutable or air-gapped backups and an untested Incident Response Plan that caused communication and containment delays.

34. Detailed Timeline of Events from Initial Compromise Through Resolution



The initial compromise, attacker dwell time discovery, containment, eradication and full recovery are all covered in this thorough account of the incident lifecycle. According to forensic evidence, the attacker had undetected access for about 21 days. After thorough credential harvesting, reconnaissance and exfiltration of regulated data, the attack culminated in the deployment of REvil ransomware. The recovery period spans over three weeks.

Each step in the NIST Incident Response life cycle is described in the timeline that follows.

Date/Time	Event Description	NIST Phase
Nov 10, 2025	Initial compromise via phishing email containing a macro-enabled document executed by an administrative staff member.	Preparation / Initial Access
Nov 11 – 17	Attacker deploys TrickBot, conducts credential harvesting and network mapping, moves laterally undetected.	Detection
Nov 18, 2025	Privilege escalation: Domain Administrator credentials compromised due to weak MFA/PAM controls.	Detection
Nov 19 – Dec 1	Approximately 340GB of member and employee PII/NPI exfiltrated to attacker C2 servers.	Detection
Dec 1 – 6:25 AM	REvil ransomware deployed across file servers and primary backup systems.	Detection
Dec 1 – 6:45 AM	SysAdmin identifies ransom notes (“READ_ME_NOW.txt”) and abnormal file activity; incident escalated.	Detection
Dec 1 – 7:00 AM	CSIRT activation; critical incident declared; infected network segments isolated to protect core banking.	Containment
Dec 1 – 2:00 PM	Third-party forensics confirms data theft and active persistence. Leadership decides against ransom payment.	Containment
Dec 2 — End of Day	Mandatory reporting submitted to NCUA and state regulators; FBI notified.	Eradication
Dec 3	Attacker posts 500 member records to a dark-web leak site; breach notifications accelerated.	Eradication
Dec 4 – 7	Full eradication initiated: complete wipe of affected systems and provisioning of clean infrastructure.	Eradication / Recovery
Dec 8 – 14	Restoration from 45-day-old offsite backups; email and core banking interface services restored.	Recovery
Dec 15 – 21	Validation phase: vulnerability scans, application integrity checks, and workstation reimaging.	Recovery
Dec 22 onward	Organization returns to full operational capacity; post-incident review and long-term security hardening initiated.	Post-Incident



➤ Attack Vector and Methodology

The incident was linked to a phishing email that contained a malicious macro-enabled document, according to forensic analysis. After the document was executed, TrickBot was installed, allowing the attacker to download additional tools, create persistence, and gradually increase their privileges.

In order to evade detection, the attacker used legitimate administrative tools (Living off the Land) and operated in a manual multi-stage manner typical of human-operated ransomware. As outlined below, the attack progression is consistent with the MITRE ATTACK framework.

MITRE-Mapped Attack Methodology

MITRE Tactic	FinanceFirst Activity	Key Security Failure
Initial Access (T1192)	Phishing email leading to execution of a malicious document.	Inadequate phishing filtering and user awareness training.
Execution (T1059)	TrickBot installation; download of secondary payloads (likely Cobalt Strike).	No EDR solution to detect suspicious execution.
Credential Access (T1003)	Credential dumping and pass-the-hash techniques; Domain Admin compromise.	No MFA on privileged accounts; weak PAM processes.
Lateral Movement (T1210)	Use of RDP/SMB to traverse admin servers and file shares.	Flat network segmentation allowed unrestricted movement.
Exfiltration (T1041)	Exfiltration of 340GB of PII/NPI over several days.	Lack of monitoring and behavioral analytics.
Impact (T1486)	Deployment of REvil ransomware on servers and backup systems.	Backups not air-gapped or immutable, Lack of proper encryption mechanisms on the servers.

➤ Systems Affected

The following systems were affected:

- **File Servers:** All primary document repositories are encrypted.
- **Backup Infrastructure:** On-site virtual backup server encrypted, eliminating recent restore points.
- **Domain Controllers:** Compromised credentials and persistence required a complete rebuild of the AD environment.
- **Workstations:** 45 administrative systems encrypted.
- **Cloud CRM / Member Portal:** Unaffected due to vendor-managed segregation.



➤ Data Impacted

The attacker accessed and exfiltrated data belonging to approximately **85,000 members** and **320 employees**, resulting in significant regulatory exposure.

Data Type	Compromised	GLBA / Regulatory Risk
Member PII/NPI	Yes: Exfiltrated	Severe: Regulatory notification is required.
Employee Records	Yes: Exfiltrated	High: Risk of identity theft.
Core Banking Data	No	Successful containment no risk to regulations.
Historical Data	Yes: Encrypted	The workload for restoration is moderate

Forensic Findings and Evidence

Logs impacted systems and data flows were thoroughly examined by a contracted forensic company. Their conclusions provided crucial information about the attackers' strategies, persistence tactics, the attack timeline, and the degree of data exfiltration. Important findings are highlighted below:

- **First Access:** The entry point was confirmed to be a phishing email that sent a macro-enabled document.
- **Dwell Time:** Before beginning encryption, the attacker remained active within the environment for twenty-one days.
- **Data Exfiltration:** Outgoing traffic of about 340GB to the attacker command and control (C2) servers was discovered in firewall and SIEM logs.
- **Persistence Mechanisms:** Full rebuilding is needed rather than part cleanup for service accounts and unauthorized scheduled tasks that are already confirmed to be involved.
- **Ransomware Family:** Found to be a custom-configured variant of REvil/Sodinokibi.

➤ Evidence Collected & Chain of Custody

In order to support regulatory and possible legal proceedings, the response team maintained a well-documented, clear, and verifiable chain of custody for all materials gathered.

Items of Evidence.

- Five server disk images.
- Dumps of memory.
- Firewall and SIEM logs.
- Ransom note artifacts.
- Attacker IP addresses are included in the list of Indicators of Compromise (IOCs).

The Practices of The Chain of Custody.



- All evidence is hashed and kept in a secure location.
- Access logs are maintained during the handling procedure.
- Information given to the FBI complies with federal regulations.

Tactics, Techniques, and Procedures of Attackers (TTPs).

By encrypting local systems and threatening to release stolen data, the attacker used a sophisticated, financially motivated ransomware approach that included social engineering, credential theft, covert internal movement, and double-extortion tactics.

Observed TTPs & Mitigation Lessons		
TTP	Description	Mitigation Lesson
First Lure	Personalized phishing aimed at administrative personnel	Ongoing phishing training based on scenarios.
Tooling	RDP PowerShell and credential dumping tools (Living off the Land)	Install EDR with the ability to detect behavior.
Network Abuse	Lateral movement in a flat network with little segmentation.	Segment using Zero-Trust.
Extortion	To increase pressure, combine encryption and data theft.	Invest in member support procedures logging and secure backups.

35. Appendices

Appendices: Supporting Documentation for the FinanceFirst Ransomware Incident

To ensure transparency, accountability, and regulatory compliance, we have compiled a set of appendices that document every critical aspect of our response to the ransomware attack at FinanceFirst Credit Union. These materials provide a clear, chronological record of what happened, how we responded, and the steps we took to protect our members and the organization.

1. Incident Timeline (Detailed)

Our timeline captures the full story of the incident, from the initial compromise to the final stages of recovery:

- **November 10:** An employee unknowingly opened a phishing email, which allowed the attacker to gain a foothold in our network.
- **November 11–17:** The attacker moved laterally, harvesting credentials and escalating privileges without detection.



- **November 18:** Domain administrator credentials were compromised, giving the attacker broad access.
- **November 19–December 1:** Sensitive data about 340GB was quietly exfiltrated.
- **December 1, 6:25 AM:** The ransomware was triggered, encrypting servers and backups. The ransom note was discovered shortly after.
- **December 1, 7:00 AM onward:** Our incident response team isolated affected systems, began forensic imaging, and notified leadership and regulators.
- **December 2–7:** We focused on containment, eradication, and restoring services from clean backups, while keeping members and regulators informed.

This timeline not only shows the sequence of events but also highlights how quickly we mobilized our response once the attack was detected.

2. Evidence Inventory and Chain of Custody

We took great care to preserve all relevant evidence, both for internal review and potential legal proceedings. Our inventory includes:

- Disk images from affected servers and workstations
- Memory dumps from critical systems
- Firewall and SIEM logs covering the attack window
- Copies of the ransom note and related artifacts
- Lists of attacker IP addresses and indicators of compromise
- The original phishing email and attachment

Each item was carefully documented, hashed, and stored securely. Access was strictly controlled and logged, and all evidence shared with law enforcement was transferred using secure, verifiable methods. This meticulous approach ensures the integrity of our investigation and supports any future legal or regulatory actions.

3. Communications Sent (Notifications, Public Statements)

Clear, timely communication was a cornerstone of our response. We issued:

- **Internal notifications** to the CISO, executive team, and CSIRT, outlining the situation and immediate actions.
- **Public statements** to reassure members and partners that core banking services remained operational, and to explain the steps we were taking.
- **Member notifications** explaining the nature of the breach, what information was involved, and the support we were offering (including free credit monitoring).
- **Regulatory notifications** to the NCUA, state regulators, and law enforcement, providing detailed incident reports and updates as required.



All communications were crafted to be honest, empathetic, and informative, avoiding technical jargon and speculation. We prioritized transparency to maintain trust and meet our legal obligations.

4. Forensic Reports (Summary)

Our forensic investigation revealed:

- The attack began with a phishing email and leveraged tools like TrickBot for credential theft and lateral movement.
- The attacker maintained undetected access for about three weeks, exfiltrating a large volume of sensitive data.
- The ransomware used was a variant of REvil/Sodinokibi, and both production and backup systems were encrypted.
- Multiple backdoors and persistence mechanisms were found, leading us to rebuild the network from scratch to ensure complete eradication.

These findings guided our recovery strategy and informed our communications with stakeholders and regulators.

5. Regulatory Correspondence

We maintained open, proactive communication with all relevant authorities:

- **NCUA:** Notified within the required 72-hour window, with updates on impact, response actions, and recovery timelines.
- **FinCEN:** Filed a Suspicious Activity Report (SAR) detailing the nature and scope of the attack.
- **State regulators and attorneys general:** Provided breach notifications as required by law, including details on affected members and remediation steps.
- **FBI and law enforcement:** Shared evidence and coordinated on investigation and threat intelligence.

By documenting every step and maintaining a clear audit trail, we demonstrated our commitment to compliance and responsible incident management.

Summary:

These appendices provide a comprehensive, transparent record of how FinanceFirst Credit Union responded to a major ransomware incident. They reflect our dedication to protecting our members, fulfilling our legal and regulatory duties, and learning from the experience to strengthen our defenses for the future.

**References**

NIST Special Publication 800-61 Revision 3, Computer Security Incident Handling Guide, National Institute of Standards and Technology.
 CISA, Ransomware Guide, Cybersecurity and Infrastructure Security Agency.
 ISO/IEC 27035, Information Security Incident Management.
 FFIEC, Cybersecurity Assessment Tool.
 FBI, Ransomware, and Cyber Extortion Guidance.
 Gramm-Leach-Bliley Act (GLBA), Safeguards Rule, and Privacy Rule.

References

<https://www.microsoft.com/en-us/security/business/security-101/what-is-privileged-access-management-pam>

References

CISA. (2023). Cybersecurity Incident & Vulnerability Response Playbooks. Cybersecurity and Infrastructure Security Agency. <https://www.cisa.gov>
 Federal Financial Institutions Examination Council (FFIEC). (2019). FFIEC Cybersecurity Assessment Tool. <https://www.ffiec.gov/cyberassessmenttool.htm>
 Federal Financial Institutions Examination Council (FFIEC). (2016). Information Security Booklet – FFIEC IT Examination Handbook. <https://ithandbook.ffiec.gov>
 Gramm-Leach-Bliley Act, 15 U.S.C. §§ 6801–6809. (1999).
 National Institute of Standards and Technology (NIST). (2018). Framework for Improving Critical Infrastructure Cybersecurity (Version 1.1). U.S. Department of Commerce. <https://www.nist.gov/cyberframework>
 National Institute of Standards and Technology (NIST). (2020). NIST Special Publication 800-61 Rev. 2: Computer Security Incident Handling Guide. <https://csrc.nist.gov/publications>
 National Institute of Standards and Technology (NIST). (2022). NIST Special Publication 800-53 Rev. 5: Security and Privacy Controls for Information Systems and Organizations. <https://csrc.nist.gov/publications>
 National Credit Union Administration (NCUA). (2023). Cyber Incident Notification Requirements. <https://ncua.gov>
 New York State Department of Financial Services (NYDFS). (2023). 23 NYCRR 500: Cybersecurity Requirements for Financial Services Companies. <https://www.dfs.ny.gov>
 SANS Institute. (2022). Incident Handler's Handbook (Version 2). <https://www.sans.org>